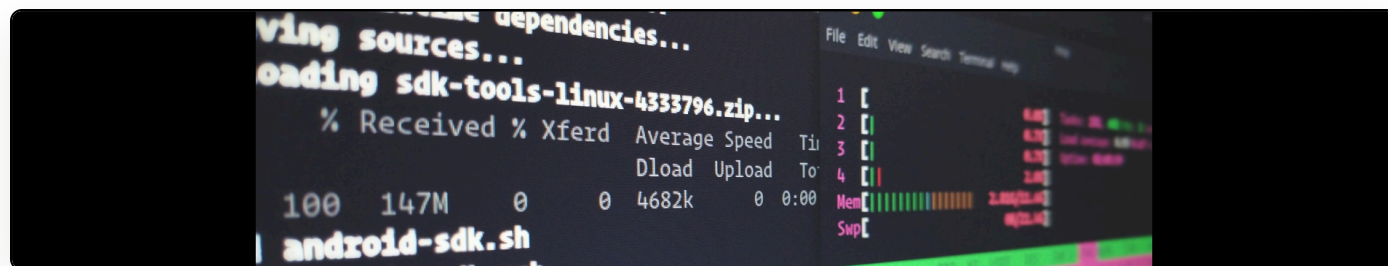


The importance of weaponization in exploit development

Cite as: Martin Paul Eve, "The importance of weaponization in exploit development", *eve.gd*:
Martin Paul Eve, September 24, 2008, <https://doi.org/10.59348/3kg3r-5z330>.



While back (quite a long while back now I suppose) I entered SmugMug's "competition" to "hack" their system. As it was hardly impenetrable I succeeded and successfully claimed a security bounty from them; although they weren't so keen to publicise that! Now, you can moralise about security bounties if you want, but I am a student and starving in a garret. In short, I have nothing to lose but my chains ;)

I feel enough time has passed and that it is now fair for me to divulge the details of the exploit as it comes with interesting connotations for weaponizing XSS payloads for demonstration in a corporate environment. One of the largest problems with security vulnerabilities is persuading companies that the danger is real, and not just an intellectual concern. This post will illustrate how I achieved that.

Well, the first aspect was easy enough - I had to locate an XSS hole. This took approximately 5 minutes. The login page itself was well sanitized, as were many fields. However, the "color scheme" option inside (an HTML SELECT element) was not. It was populated from a querystring that was neither sanitized nor protected against CSRF in any way. This was handy for two reasons. First point then, although it would have been possible to CSRF their password page directly, this would

mean asking the CEO to "visit my web page" - which again can seem too theoretical. By identifying an XSS vulnerability I would be able to illustrate the vulnerability by visiting HIS own site. This seems far more impressive to the man-in-the-suit - it's an attack on home turf.

Once I had identified this weakness I proceeded to inject the universal tag that I had formulated earlier (it's all very Blue Peter ya know!) which invoked either a XBL loader or, for IE, a direct JavaScript injection. I figured it was 90% likely that my intended audience would be using either of these browsers. Point number 2: it is far more impressive to anticipate the attack environment than to say "oh, it only works in Firefox but I can easily make it work in IE." If you can make it work, do.

Anyway, so my JavaScript then offsite-loaded the cookie into an SSImp module that I had written which instantly connected back to the site and changed the user's password and email to my own. In other words, a total account compromise: their competition had only asked for a single photo to be hijacked. I had completely compromised the admin account. Point number 3: if you can go further than they ask then go for it!

Anyway, I want to argue that, regardless of the potential for malicious abuse, techniques of weaponization and professionalism in exploit demonstration ARE important. It was a difficult task to get SmugMug to pay me and took a long time. I have little doubt that, had the exploit not been fully functional and weaponized, I would not have been paid. Point number 4: always have a backup plan. Without resorting to blackmail (as in, there is an advertised bounty not being honored), politely inform your non-payees that the vulnerability disclosed was not the only one.

Yours evilly,

Martin